

TLP:CLEAR

Анализ угроз на основе ханипотов

Ежемесячный отчёт — июнь 2026

Docker-червь / Escape-to-Host | ELF SSH-черви | Solana Targeting | LLM Abuse | IEC-104 Recon

Параметр	Значение
Период отчёта	1-30 июня 2026 (2026-06-01 — 2026-07-01 UTC)
Дата анализа	7 июля 2026
Классификация	TLP:CLEAR
Уровень угрозы	СРЕДНИЙ-ВЫСОКИЙ
Узлы ханипотов	DE, US, RU + IEC-104 (ICS/OT) приманка
Объём событий	~870 000 атакующих сессий/запросов по всем сервисам
SSH-события	497 929 сессий, 433 721 неудачный логин, 516 payload-загрузок
Образцы малвари	70 уникальных SHA-256 (все вредоносные)

1. Краткое заключение

За июнь 2026 распределённые сенсоры-приманки (Германия, США, Россия) зафиксировали около 870 000 атакующих сессий/запросов по векторам SSH, многопротокольной эксплуатации, Docker, LLM, MikroTik и Kubernetes (≈2,9 млн «сырых» событий Cowrie с учётом низкоуровневых записей). Главное событие месяца — самораспространяющийся червь для Docker API с побегом из контейнера на хост: объём Docker-поверхности вырос примерно в 28 раз за месяц (≈4 300 → ≈119 000 событий) усилиями одного оператора.

Второй заметный сдвиг — в пойманной малвари: майское доминирование WannaCry/SMB (PE32-DLL) в июне сменилось почти целиком ELF SSH-червями (Panchan, Go SSH-worm, Discord-C2, Mirai/Gafgyt). Продолжается таргетинг Solana-валидаторов, злоупотребление LLM-эндпоинтами держится как отдельная категория, а IEC-104 (ICS/OT) приманка фиксирует устойчивую разведку без единой управляющей команды от внешних атакующих.

2. Сводка по объёмам

SSH (Cowrie), точные счётчики:

Метрика	DE	US	RU	Всего
Сессии	228 211	88 586	181 132	497 929
Успешные логины	13 991	1 466	4 249	19 706
Неудачные логины	200 416	83 686	149 619	433 721
Команды в shell	4 656	1 221	1 713	7 590
Скачанные payload-ы	413	103	0	516

Агрегаты по флоту: Dionaea (SMB/MSSQL/MySQL/FTP/SIP) 224 985; Docker API 118 909; Ollama (LLM) 16 729; Winbox (MikroTik) 6 871; Kubelet 3 211. Германия стала самым нагруженным SSH-сенсором (228K сессий) и показала необычно высокий success rate 6,5% — словарь конкретного ботнета совпал с decoy-кредами. Россия снова получила ноль payload-загрузок (третий месяц подряд): атакующие ведут разведку (uname), но до доставки не доходят.

3. Находка 1 — Docker-API червь с побегом на хост (заглавная)

Фейковый Docker API получил 118 909 запросов, рост ~28× к маю. Один оператор — 45[.]198[.]224[.]5 (VPSVAULT.HOST LTD, AS215925) — сделал 104 299 из них (88%) и фигурирует в botnet-телеметрии как собственный узел кампании. Именно он поднял VPSVAULT.HOST со 157 operator-hits в мае до 1 487 в июне.

Механика (из тел containers/create, JA4H-кластер po11nn0*): червь тянет распространённые образы (postgres:16, redis:7-alpine, nginx:latest, debian, ubuntu, busybox, alpine), создаёт контейнер с монтированием ФС хоста и вырывается на хост через chroot /host|/mnt|/hostfs sh (T1611). Вторая стадия — base64-команда в Cmd, загружающая payload с хоста второй стадии (придержан вне публичных IOC) (вероятно криптомайнер/лоадер). Методы: POST 105 642, GET 12 450, DELETE 65.

Это зрелый самораспространяющийся Docker-червь: открытый Docker API → побег на хост → загрузка второй стадии. Отдельный технический отчёт по этой кампании выйдет позже.

4. Находка 2 — Малварь сместилась к ELF SSH-червям

70 уникальных образцов, все вредоносные, преимущественно через Cowrie. В отличие от мая, где ~85 из 126 образцов были PE32-DLL WannaCry с SMB-поверхности, июньский поток почти целиком ELF: YARA SUSP_XORed_Mozilla_Oct19 (12), Panchan_SSHWorm_Go (10), Go_SSHWorm_Generic (10), Discord_C2_ELF (10), SUSP_ELF_LNX_UPX_Compressed (9, UPX-упаковка), Mirai_Botnet_Malware (3), а также MAL_ELF_Xlogin и ARM-Mirai. Теги C2-методов: gafgyt (10), mirai (7), xor (6). PE32+ образец в этом месяце ровно один. ClamAV дал ноль детектов по всем 70 — поток ловится только YARA/imphash.

Основные дропперы (Cowrie file_download):

Dropper	Загрузок	Профиль
45[.]142[.]142[.]140:8443/dropper_x86	61	одиночный x86
192[.]142[.]28[.]77/bachekuni/ohshit.*	~100	полный мульти-arch (arm/mips/ppc/sh4/i686/x86...)
51[.]158[.]248[.]122:8517/*	~30	мульти-arch + loader
202604157[.]xyz/snh5ye.sh	8	shell-loader (домен)

Выбор архитектуры — через /bin/./uname -s -v -n -r -m (831) перед доставкой.

5. Находка 3 — Злоупотребление LLM-эндпоинтами (продолжается)

Фейковый Ollama API дал 16 729 событий. Таксономия: сканирование ~79% (12 923), кража inference/compute ~17% (2 810), злоупотребление внешними/облачными моделями ~3,4% (557) и всего 4 события ssrf_cloud_cred (резкий спад с майских ~0,5%). Целевые эндпоинты: /api/tags (6 154, инвентаризация моделей), /api/generate, /v1/models, /v1/chat/completions, /api/pull, а также /etc/passwd (36, LFI-проба).

В запросах — как локальные модели (qwen2.5:7b, llama3.1:8b, codellama:13b), так и платные облачные (glm-5.2:cloud, deepseek-v4-pro:cloud, minimax-m3:cloud, kimi-k2.7-code:cloud) — попытки прокинуть коммерческий inference через приманку. Основной сканер сменился с майского официального Ollama Go-client на node-fetch/1.0 (4 843), рядом Go-http-client, axios, security-scan, коммерческий EchelonGraph-ShadowAIRadar и Umai-Scanner.

6. Находка 4 — SSH-брутфорс и таргетинг Solana

Топ-источники: 45[.]148[.]10[.]183 (41 425), 45[.]156[.]87[.]254 (34 598), 45[.]148[.]10[.]240 (30 052), 2[.]57[.]122[.]177, 94[.]154[.]35[.]215, 185[.]246[.]128[.]133, 176[.]65[.]132[.]24. В словарях устойчиво Solana-специфичные креды — username sol (5 906), solana (5 773), solv (3 050); password solana (1 796), sol (1 614) — ботнет ищет Solana-валидаторы для кражи ключей/перенаправления стейкинга. Новое в этом месяце: username claudе (2 173), openclaw (1 636) и frappe (1 524, ERPNext).

7. Находка 5 — ICS/OT-приманка (IEC-104)

IEC-104 (ICS/OT-протокол) приманка за полный месяц наблюдения зафиксировала внешнюю атакующую активность — 758 подключений и 67 общих опросов (General Interrogation, перечисление точек данных ASDU) при нулевом числе управляющих команд — только разведка. Источники — 267 уникальных внешних IP, преимущественно облачные сканеры, ведущие массовую ICS-перепись, а не таргетированное вторжение. Артефакты симуляции/отладки и трафик с нашей же авторизованной red-team точки из этих цифр исключены. Вывод: интернет-широкая разведка IEC-104 рутинна, но ручного вмешательства в эмулированную логику управления не было вовсе.

8. Операторы-источники и география

Ведущие операторы (пассивная ASN-атрибуция): DigitalOcean (6 468), OVH (1 707), VPSVAULT.HOST (1 487 — Docker-червь), Alibaba Cloud (666), Amazon AWS (364), GCS (158), M247 (95); санкционные/BPH несут малый объём — Aeza (31), Proton66 (10), UFO Hosting/Stark (5). Топ стран по объёму атак: US (29 897), CN (8 016), NL (7 355), RO (3 709), DE (3 350), SG (2 906), RU (2 692), HK, GB, VN. Основной объём — легитимные облака (арендованные VPS-ботнеты); таргетированную Docker-worm нагрузку в этом месяце нёс VPSVAULT.HOST.

9. Ботнет-кампании

~7 отслеживаемых кампаний, охват ~78 атакующих IP; ~2 930 botnet-атак по ~43 конечным точкам сенсоров. Активные C2: 217[.]60[.]195[.]113 (AE, размер до 19), 14[.]46[.]136[.]77 (KR, до 13, тянется с мая), 213[.]108[.]21[.]95 (NL, AS210644 Aeza, санкционный).

10. MITRE ATT&CK

- T1595.002 — Active Scanning: Vulnerability Scanning
- T1110 — Brute Force
- T1046 — Network Service Discovery
- T1190 — Exploit Public-Facing Application
- T1610 — Deploy Container
- T1611 — Escape to Host (Docker-червь)
- T1496 — Resource Hijacking
- T1552.005 — Cloud Instance Metadata API
- T0846 — Remote System Discovery (IEC-104 connect, ICS)
- T0888 — Remote System Information Discovery (General Interrogation, ICS)

11. Индикаторы компрометации (IOC)

Машиночитаемые дампы — iocs.stix2.json (STIX 2.1) и iocs.misp.json (MISP) — поставляются вместе с отчётом. В человекочитаемых документах индикаторы обесфанджены, в JSON-бандлах — рефанджены.

TLP:CLEAR — Этот документ может распространяться без ограничений.